

Zero-Day

Five things the word names, and what the shot count is actually counting

The question this file exists to answer is already written on my Headspace page.

“What is zero-day? Is the defense against zero-days a zero-shot or few-shot challenge?”

Headspace, under the opponent modeling question

The short answer is that the second question cannot be asked until the first one is settled, because the word names five different things across my own files and the shot count comes out differently for each. The shot count is a property of the label space, not of the attack. Once you say whose label space, the question answers itself, and it answers itself differently every time.

Contents

1	The occurrences	2
2	The senses	2
2.1	Sense one, unknown to whoever could fix it	3
2.2	Sense two, the counting unit	3
2.3	Sense three, absent from the training set	3
2.4	Sense four, outside the enumerated catalog	3
2.5	Sense five, new to the person being studied	3
3	The assignment	4
4	Zero-shot or few-shot	4
5	Where the senses disagree	5
6	Placement on the five dimensions	6
7	The entry	6
8	Sources	7

1 The occurrences

Five, across three projects and one page of questions.

the scope exclusion

“We do not consider zero-day exploits beyond the four CVE-class vulnerabilities”

FOE-Dreamer, sections/04_threat_model_and_testbed.tex, threats out of scope, where the four are listed in the vulnerability table

The sentence sits between two other exclusions, adaptive learning adversaries and attacks on the defender’s own machine-learning components. In that list the word is doing scoping work and no more.

the experimental condition

“Whether role dependencies raise complementarity in a human-AI defense team facing zero-day attacks, and which of the leader, pool and informational dependencies carry the effect.”

website, FriendOrFoe, the research question

the ten scenarios

The FriendOrFoe IDS pipeline names ten of them: WannaCry, Data Theft over FTP or SSH, ShellShock, Netcat Backdoor, passwd-gzip-scp, Phishing, Cheating Student, wget-gcc, VPNFilter, and Pass-the-Hash. Each is grounded by filtering public labeled traffic, UNSW-NB15 by attack category and destination port, CICIDS2017 by label, into thirty-event tables at a fixed false-alarm percentage. One of the six built tables is called No_Attack.

Locator: the FriendOrFoe documentation folder `IDS_zero_day_generation`, its ten-scenario document, its `zero_day_templates.json`, and the step six assembly summary.

the generalization question

“How do we best factorize the model so that it is maximally generalizable to novel scenarios with zero/few-shot training?”

website, Cyber World Modeling, ongoing and future work, question three

This one carries the shot vocabulary without the word zero-day, which is what makes it the useful control on the Headspace question.

unseen attacker classes

The FOE-Dreamer limitations section keeps adaptive learning adversaries out of scope and names generalizing to attackers that adapt to the deployed defender as the next direction. My own wording standard translates handling unseen attackers into zero-shot transfer to unseen attacker classes, which fixes the label space at the attacker class rather than at the exploit.

2 The senses

2.1 Sense one, unknown to whoever could fix it

“An attack that exploits a previously unknown hardware, firmware, or software vulnerability.”

NIST CSRC glossary, zero day attack, sourced to CNSSI 4009-2022 and NISTIR 8011 Volume 3

The unknown party is the vendor, the maintainer, or the deploying organization, and the moment is before a patch exists. The nearest neighbor in the field’s own vocabulary is the n-day, a vulnerability that is public, has a CVE identifier and a patch, and is unpatched here anyway. Disclosure plus patch is what converts one into the other.

2.2 Sense two, the counting unit

Wang, Jajodia, Singhal, Cheng and Noel define a security metric over zero days without ever identifying one. The metric counts the smallest number of distinct unknown vulnerabilities an attacker would need to reach an asset, and a larger count means a safer network. The identity of each flaw is deliberately left out of the model, because the point of the metric is to measure risk from flaws nobody can enumerate.

Here a zero day is not an event and not a class. It is a unit of distance.

2.3 Sense three, absent from the training set

“ML-based NIDSs face new attack traffic known as zero-day attacks, that are not used in the training of the learning models due to their non-existence at the time.”

Sarhan, Layeghy, Gallagher and Portmann 2021, abstract

The unknown party here is the fitted model, and the moment is fit time. Age in the world is irrelevant: an attack disclosed a decade ago is a zero day to a model whose training set omitted it.

2.4 Sense four, outside the enumerated catalog

My own paper’s usage. Four CVE-class vulnerabilities are named in a table, the exploit paths for those four are real code, and everything else is out of scope by declaration. The word marks the boundary of an enumeration that the testbed actually implements.

2.5 Sense five, new to the person being studied

The FriendOrFoe usage. The defender in the study has not seen this scenario before, and the design turns on that. The attacks themselves are historical, published, patched, and in some cases famous.

3 The assignment

Occurrence	Sense	Why
zero-day exploits beyond the four CVE-class vulnerabilities	four	Scoping against an enumeration the testbed implements, not a claim about anyone’s knowledge.
a human-AI defense team facing zero-day attacks	five	The novelty is the participant’s. Nothing in the design requires the vendor to be ignorant of anything.
the ten scenarios	five, presented as one	WannaCry and ShellShock have public CVEs and patches. Under sense one none of the ten qualifies, and one of them is No_Attack.
novel scenarios with zero/few-shot training	three	The label space is the model’s, and the question is about what the factoring carries across.
zero-shot transfer to unseen attacker classes	three	Same label space, with the class fixed at attacker behavior rather than at exploit.

Sense two appears nowhere in my files. I record it because it is the only one of the five that treats a zero day as countable, and because a security-metrics audience will hear it first.

4 Zero-shot or few-shot

Both terms presuppose a fixed label space in which the new thing is a class. Zero-shot needs no labeled examples of the unseen class but does need an attribute description of it, expressed in a vocabulary shared with the seen classes. Few-shot needs k labeled examples and no attribute channel. That is the whole distinction, and it is a distinction about what is supplied, not about how hard the problem feels.

Now run the Headspace question through the five senses.

Sense one gives neither. At the moment of the attack there is no example and no attribute vector, because the class is not in the label space at all. That is open-set detection: the decision is whether this belongs to any known class, not which unseen class it is. Calling it zero-shot imports an attribute channel that sense one says does not exist, without saying where it came from.

Sense three gives zero-shot, but only because someone built the attribute channel by hand. Sarhan et al. make it work in two stages:

“In the attribute learning stage, the ML models map the network data features to distinguish semantic attributes from known attack (seen) classes. In the inference stage, the models are evaluated in the detection of zero-day attack (unseen) classes by constructing the relationships between known attacks and zero-day attacks.”

Sarhan et al. 2021, abstract

The zero-shot framing is available here because the attack classes were given semantic attributes derived from the known ones. Their own result is that this fails for the attacks whose feature distribution is furthest from the training classes, which is the honest statement of the limit: the

method works where the new class was almost in the old vocabulary.

Sense four gives no shots at all. It is a scoping sentence in a threat model. Nothing is being learned in it.

Sense five gives few-shot at most, and probably not even that. A human analyst has years of examples of file encryption and of internal port scanning. The scenario is new. The constituent behaviors are not. What the study manipulates is the participant’s familiarity with an assembled scenario, which is an experimental condition, not a learning regime.

So the framing is right only after the word is disambiguated, and the version of the question worth carrying forward is: whose label space, and what plays the role of the attribute channel. For FOE-Dreamer the second half already has an answer. The attribute channel is the factored representation, and the claim the factoring makes is that attacker-driven variation is separable enough to transfer while the rest of the state is not. That is a testable claim about an attribute channel, and it is a better question than counting shots.

The success criterion I already fixed for that project is stated in the same shape. The detector fires before the attacker reaches the region the model is wrong about, at a false-alarm rate an operator will accept. That is an open-set criterion. It does not ask which unseen class arrived, and it does not need to.

5 Where the senses disagree

Ten zero-day scenarios, none of which is a zero day

The FriendOrFoe scenario set names WannaCry, ShellShock, Netcat Backdoor, Pass-the-Hash and VPNFilter. Every one is historical and patched, and the events in the tables are drawn by filtering UNSW-NB15 and CICIDS2017, datasets that predate the study.

Under the NIST definition none of the ten qualifies. Under sense five all ten do, because the participant has not seen them. The set also contains No_Attack, which no reading of sense one can accommodate.

This is not a defect of the design. The design needs unfamiliarity to the participant and nothing else. It is a defect of the label, and it will misfire the moment a security reader sees the file name.

My own paper and my own experiment use the word in opposite directions

The paper excludes zero-days to bound what the testbed has to implement: the four CVE-class vulnerabilities are the enumeration, and the exclusion is what makes the threat model finite. The FriendOrFoe study includes zero-days as its central manipulation, and its zero-days are drawn from published catalogs.

One usage points outside a named list, the other points inside one. A reader who holds both papers has no way to recover a single meaning.

The training-set sense makes the word depend on the reader’s calendar

Under sense three an attack is a zero day relative to a model, so the same traffic is a zero day for one detector and routine for another trained a month later. Nothing about the attack changed.

This is the sense that makes zero-day detection rates comparable across papers only when the training split is stated, and it is the reason a reported zero-day detection rate without its held-out class list says nothing.

Countable and uncountable at the same time

The k-zero-day metric requires zero days to be countable and interchangeable: k of them, any k, is the whole content of the measurement.

Every other sense treats a zero day as an event with an identity, something that happened on a date to a specific piece of software.

A sentence that mixes the two, for example one that reports how many zero-days a defender survived, is reporting a count under sense one where only sense two licenses counting.

6 Placement on the five dimensions

- **Object.** Sense one, a vulnerability. Sense two, a unit of distance to an asset. Sense three, a class absent from a training set. Sense four, a boundary around an enumeration. Sense five, a scenario presented to a person.
- **Epistemic operation.** Describe, measure, detect, scope, manipulate. Only sense three is an inference problem, which is why only sense three admits the shot vocabulary at all.
- **Specificity.** Sense one is a particular flaw. Sense two is deliberately generic and refuses to name the flaw. Sense five is a particular scenario assembled from generic parts.
- **Purpose.** Warn, quantify, detect, bound the threat model, elicit behavior from a human.
- **Fidelity.** Sense four is executable in my case: the four exploit paths are real code on real services. Sense five is reproduced at the level of network events in a table, not at the level of running software. Sense two is abstract by construction.

Specificity and fidelity again move together and the table cannot show it, in the opposite direction from the population entry. Sense two buys its generality by giving up any executable content, and sense four buys its executable content by naming four vulnerabilities and no more. A placement that treats the two axes as independent will admit a maximally generic zero day that is also executable, and that combination is what the k-zero-day metric was invented because you cannot have.

7 The entry

Definition. An attack whose enabling flaw was unknown, at the moment it was used, to the party who would otherwise have prevented it. Which party, and which moment, is not fixed by the word and has to be supplied.

Distinguishes it from. The n-day, which is public, has a CVE identifier and a patch, and is unpatched on this network anyway. Disclosure together with a patch is the event that converts one into the other, and most of what is called a zero day in an experimental setting is an n-day that the person or the model in front of it has not met.

Operational test. Name the party the attack is unknown to and the moment at which it is unknown. The vendor, at disclosure, gives sense one. The model’s training set, at fit time, gives sense three. The participant, at the start of the session, gives sense five. If the sentence still reads correctly after you substitute a different party, it was not carrying a definition.

A second test, for whether the shot vocabulary applies: ask what attribute description of the new class the method receives. If none, the problem is open-set detection and no shot count applies. If some, the problem is zero-shot and the attribute channel is the thing to argue about. If labeled examples arrive, it is few-shot and the count of examples is the parameter.

In my project. FOE-Dreamer uses sense four, once, to bound the threat model, and its live question is stated as open-set detection: whether drift in the opponent latent can be detected before it is exploited. FriendOrFoe uses sense five, as its central manipulation, over ten scenarios drawn from published catalogs. Cyber World Modeling’s third ongoing question uses sense three without using the word, and asks whether a factorization can be built that carries to novel scenarios under zero or few-shot training. That question and the Headspace question are the same question, and the factored representation is the candidate answer to both.

8 Sources

- NIST Computer Security Resource Center glossary, entry zero day attack, sourced to CNSSI 4009-2022 and NISTIR 8011 Volume 3.
- Wang, L., Jajodia, S., Singhal, A., Cheng, P., and Noel, S. k-Zero Day Safety: A Network Security Metric for Measuring the Risk of Unknown Vulnerabilities. *IEEE Transactions on Dependable and Secure Computing* 11(1), 2014.
- Sarhan, M., Layeghy, S., Gallagher, M., and Portmann, M. From Zero-Shot Machine Learning to Zero-Day Attack Detection. arXiv 2109.14868, 2021.
- My own files: the Headspace page, the FriendOrFoe page `friendorfoe.md`, the Cyber World Modeling README, the FOE-Dreamer threat model and testbed section together with its discussion and limitations section, and the FriendOrFoe IDS pipeline under `IDS_zero_day_generation`, with its ten-scenario document, its `zero_day_templates.json`, and the step six assembly summary.
- The UNSW-NB15 and CICIDS2017 datasets, named in the ten-scenario document as the grounding for the generated event tables.